

Checklist

Secure Network Infrastructure

1. Device Hardening

- ☐ Disable unnecessary services and management interfaces.
- ☐ Replace insecure/default configurations with hardened configurations.
- ☐ Use established security baselines such as CIS Benchmarks where appropriate.
- ☐ Enable encryption for administrative and management traffic.
- ☐ Restrict administrative access to authorized users and systems.
- ☐ Change all default usernames, passwords, and community strings.
- ☐ Keep device firmware and software supported and up to date.
- ☐ Regularly review configurations for unnecessary or risky settings.

2. Firmware and Software Patching

- ☐ Maintain an inventory of routers, switches, WAPs, firewalls, VPN appliances, and other network devices.
- ☐ Regularly check vendors for patches, firmware releases, and security advisories.
- ☐ Review release notes before installing an update.
- ☐ Confirm the device model and hardware revision support the update.
- ☐ Download firmware only from the official vendor.
- ☐ Verify the integrity/signature of downloaded firmware when supported.
- ☐ Back up the current device configuration before upgrading.
- ☐ Document the recovery or rollback procedure.
- ☐ Notify stakeholders before a change that may cause an outage.
- ☐ Schedule upgrades through the organization's change-control process.
- ☐ Install the update according to vendor instructions.
- ☐ Restart the device when required.
- ☐ Perform functional testing after the upgrade.
- ☐ Confirm monitoring systems show the device operating normally.

- ☐ Communicate the outcome of the change to affected stakeholders.

3. Services and Open Ports

- ☐ Scan network devices to identify listening TCP and UDP ports.
- ☐ Verify that every open port has a legitimate business purpose.
- ☐ Disable services that are not required.
- ☐ Investigate unexpected management services on high-numbered ports.
- ☐ Restrict management services to trusted management networks.
- ☐ Replace Telnet with SSH wherever possible.
- ☐ Replace HTTP management interfaces with HTTPS.
- ☐ Review UDP services such as SNMP and time synchronization.
- ☐ Repeat port scans after configuration changes to verify hardening.
- ☐ Conduct authenticated vulnerability scans when possible.

4. Infrastructure as Code / DevOps

- ☐ Consider managing network configurations as code.
- ☐ Store configuration templates in version control.
- ☐ Use peer review and change-control processes for configuration changes.
- ☐ Use automated deployment/testing where appropriate.
- ☐ Store credentials, API keys, and other secrets in a dedicated secrets-management system.
- ☐ Never commit passwords or other secrets directly into configuration repositories.
- ☐ Test automated configuration changes before production deployment.

5. SNMP Security

- ☐ Avoid SNMPv1.
- ☐ Avoid SNMPv2c where possible.
- ☐ Prefer SNMPv3 with authentication and encryption.
- ☐ Never leave SNMP community strings set to defaults such as **public** or **private**.
- ☐ Use strong, unique SNMP credentials.
- ☐ Restrict SNMP access to authorized management systems.
- ☐ Limit read/write SNMP permissions to systems that actually require them.
- ☐ Prevent publicly accessible SNMP services.
- ☐ Monitor for unauthorized SNMP queries.
- ☐ Check that SNMP cannot be abused as a DDoS amplification service.

6. Encrypted Management Protocols

- ☐ Use SSH rather than Telnet for command-line administration.
- ☐ Use HTTPS/TLS rather than HTTP for web-based administration.
- ☐ Disable insecure management protocols whenever possible.
- ☐ Replace devices that cannot support secure management protocols.
- ☐ If insecure management cannot immediately be removed, restrict access as much as possible.
- ☐ Document and formally accept any remaining risk.

7. Management Network

- ☐ Create a dedicated management network or VLAN.
- ☐ Restrict management interfaces so they are reachable only from the management network.
- ☐ Do not expose management interfaces directly to the public internet.
- ☐ Use a hardened bastion host/jump box or VPN for administrative access.
- ☐ Require strong authentication for access to the management network.
- ☐ Apply least privilege to administrative users.
- ☐ Use role-based access control where supported.
- ☐ Consider privileged access management for sensitive systems.
- ☐ Log administrative activity centrally.
- ☐ Consider Zero Trust Network Access or software-defined perimeter approaches for high-security environments.

8. Bastion Hosts

- ☐ Use a hardened bastion host as a controlled administrative entry point.
- ☐ Install only software and services required for administration.
- ☐ Patch the bastion host frequently.
- ☐ Require strong authentication/MFA.
- ☐ Restrict which administrators can connect.
- ☐ Restrict which network devices can be reached through the bastion host.
- ☐ Log and audit administrative sessions where possible.

9. Router Security

- ☐ Patch router firmware regularly.

- ☐ Disable unnecessary services.
- ☐ Secure all router management interfaces.
- ☐ Use ACLs to explicitly permit required traffic.
- ☐ Deny unnecessary traffic by default.
- ☐ Apply ACLs to the correct interfaces and directions.
- ☐ Restrict administrative protocols to trusted subnets.
- ☐ Review routing protocol security.
- ☐ Authenticate dynamic routing protocols when supported.
- ☐ Protect against malicious or unauthorized route advertisements.
- ☐ Review the appropriate CIS Benchmark or vendor hardening guide.

10. Switch Security

- ☐ Segment networks using VLANs appropriately.
- ☐ Do not treat VLANs as equivalent to physical isolation.
- ☐ Protect against VLAN hopping.
- ☐ Enable port security on access ports.
- ☐ Limit the number of MAC addresses permitted per port.
- ☐ Disable unused switch ports.
- ☐ Place unused ports in an unused/restricted VLAN where appropriate.
- ☐ Enable DHCP snooping where supported.
- ☐ Enable Dynamic ARP Inspection where supported.
- ☐ Consider private VLANs for additional segmentation.
- ☐ Protect against MAC spoofing.
- ☐ Secure spanning-tree configurations.
- ☐ Review the appropriate CIS Benchmark or vendor guidance.

11. Wireless and IoT Devices

- ☐ Maintain an inventory of wireless and IoT devices.
- ☐ Patch wireless devices and IoT firmware regularly.
- ☐ Remove or isolate devices that are no longer supported.
- ☐ Disable unnecessary wireless technologies and interfaces.
- ☐ Apply strong access controls to IoT devices.
- ☐ Segment IoT devices from sensitive systems.
- ☐ Secure device web-management interfaces.
- ☐ Monitor for unauthorized wireless devices.

Bluetooth

- ☐ Disable Bluetooth when it is not required.
- ☐ Avoid unnecessary discoverable/pairing modes.
- ☐ Keep Bluetooth-capable devices patched.
- ☐ Monitor for unauthorized connections where appropriate.

Cellular

- ☐ Prefer current-generation cellular technologies where available.
- ☐ Be aware of weaknesses in legacy 2G/3G networks.
- ☐ Protect sensitive applications independently of the cellular transport.

Zigbee

- ☐ Use supported encryption features.
- ☐ Protect Zigbee-connected devices with strong access controls.
- ☐ Patch vulnerable IoT gateways and web interfaces.

NFC

- ☐ Limit NFC use to required applications.
- ☐ Use encryption and payment/security standards where applicable.
- ☐ Be aware of physical-proximity attacks in crowded environments.

12. Wi-Fi Security

- ☐ Do not use WEP.
- ☐ Avoid legacy WPA/TKIP.
- ☐ Use WPA2 with AES/CCMP at minimum where WPA3 is unavailable.
- ☐ Prefer WPA3 for supported devices.
- ☐ Use strong, unique wireless credentials.
- ☐ Avoid weak pre-shared keys.
- ☐ Use enterprise authentication where appropriate.
- ☐ Keep access points and wireless controllers patched.
- ☐ Detect and remove rogue access points.
- ☐ Monitor for evil-twin access points.
- ☐ Protect against deauthentication/disconnection attacks where supported.
- ☐ Review wireless logs for suspicious activity.

13. Network Segmentation

- ☐ Separate sensitive systems from general user networks.
- ☐ Separate management traffic from ordinary user traffic.
- ☐ Place public-facing systems in appropriately isolated network segments.
- ☐ Separate IoT and other less-trusted devices.
- ☐ Restrict traffic between segments using firewalls or ACLs.
- ☐ Allow only explicitly required communications between segments.
- ☐ Regularly verify segmentation controls.

14. Egress Filtering

- ☐ Filter outbound as well as inbound traffic.
- ☐ Permit only necessary outbound protocols and destinations where practical.
- ☐ Restrict systems from reaching unexpected external IP addresses.
- ☐ Restrict unnecessary outbound ports.
- ☐ Log denied outbound connections.
- ☐ Monitor for command-and-control traffic.
- ☐ Investigate unusual outbound connections.
- ☐ Use egress controls to make data exfiltration more difficult.
- ☐ Review dropped outbound traffic for compromised internal hosts.

15. IPv6 Security

- ☐ Determine where IPv6 is enabled across the organization.
- ☐ Do not assume IPv6 is unused simply because the network primarily uses IPv4.
- ☐ Create security policies for IPv6 traffic.
- ☐ Configure firewalls to inspect and filter IPv6.
- ☐ Monitor IPv6 traffic.
- ☐ Account for IPv6 link-local addresses.
- ☐ Identify and control IPv6 tunneling mechanisms such as Teredo, 6in4, 6to4, and 6rd.
- ☐ Avoid blindly blocking IPv6 without evaluating operational impact.
- ☐ Ensure security tools can detect IPv6-based attacks.
- ☐ Apply equivalent security controls to IPv4 and IPv6.

16. Centralized AAA / TACACS+

- ☐ Use centralized authentication for network-device administration.
- ☐ Consider TACACS+ for network infrastructure.
- ☐ Centralize authorization and accounting.
- ☐ Ensure administrators have individual accounts.
- ☐ Avoid shared administrative accounts.
- ☐ Remove access promptly when administrators leave or change roles.
- ☐ Apply separation of duties.
- ☐ Send administrative logs to a centralized logging platform.
- ☐ Regularly review privileged account activity.

17. ARP and MAC-Layer Attacks

- ☐ Enable protections against ARP cache poisoning.
- ☐ Enable Dynamic ARP Inspection where supported.
- ☐ Enable DHCP snooping.
- ☐ Enable switch port security.
- ☐ Limit permitted MAC addresses on access ports.
- ☐ Monitor for unexpected MAC-address changes.
- ☐ Investigate suspicious ARP activity.
- ☐ Use encrypted protocols so intercepted traffic remains protected.

18. DDoS Protection

- ☐ Ensure public services cannot be abused as DDoS amplifiers.
- ☐ Restrict externally accessible UDP services.
- ☐ Prevent open DNS, SNMP, and similar amplification services.
- ☐ Place critical public-facing services behind appropriate DDoS protection/CDN services.
- ☐ Restrict direct access to origin servers when using a reverse proxy/CDN.
- ☐ Develop a DDoS response plan.
- ☐ Monitor traffic for abnormal volume and patterns.

19. VPN Security

- ☐ Keep SSL-VPN and IPsec-VPN appliances fully patched.
- ☐ Regularly review VPN-vendor security advisories.
- ☐ Require MFA for remote-access VPNs.
- ☐ Disable unused VPN accounts.

- ☐ Protect VPN credentials.
- ☐ Restrict VPN users to only the resources they require.
- ☐ Log and monitor remote-access activity.
- ☐ Investigate unusual login locations, times, and patterns.

20. Wireless Attack Monitoring

- ☐ Monitor for weak or obsolete Wi-Fi security configurations.
- ☐ Detect rogue access points.
- ☐ Detect evil-twin access points.
- ☐ Monitor for repeated deauthentication attacks.
- ☐ Be aware of Wi-Fi jamming/interference.
- ☐ Investigate unexplained wireless outages.
- ☐ Consider wireless intrusion-detection capabilities for sensitive environments.
- ☐ Consider physical security measures where deliberate RF interference is a concern.

21. Monitoring and Auditing

- ☐ Centralize network-device logs.
- ☐ Monitor authentication failures.
- ☐ Monitor configuration changes.
- ☐ Alert on unexpected device reboots.
- ☐ Alert on new or unexpected listening services.
- ☐ Review firewall and ACL logs.
- ☐ Review denied egress traffic.
- ☐ Monitor for unusual routing changes.
- ☐ Monitor for unauthorized devices.
- ☐ Periodically scan infrastructure for vulnerabilities.
- ☐ Periodically validate that hardened configurations remain in place.

Final Review

- ☐ All network devices are inventoried.
- ☐ All network devices are running supported software/firmware.
- ☐ Default credentials have been removed.
- ☐ Unnecessary services and ports are disabled.
- ☐ Administrative traffic is encrypted.

- ☐ Management interfaces are isolated.
- ☐ Least privilege is enforced.
- ☐ Network segmentation is implemented and tested.
- ☐ Inbound and outbound filtering are configured.
- ☐ SNMP is securely configured.
- ☐ Wireless networks use modern security protocols.
- ☐ IPv6 receives the same security attention as IPv4.
- ☐ VPN infrastructure is patched and monitored.
- ☐ DDoS protections are in place for public-facing services.
- ☐ Central logging and monitoring are enabled.
- ☐ Backups of device configurations are current.
- ☐ Recovery procedures have been tested.
- ☐ Configuration and security reviews are performed regularly.